

Active Directory Home Lab

Group Policy Objects (GPO)

Platform: Oracle VirtualBox | OS: Windows Server 2022 + Windows 11

Overview

Group Policy Objects (GPOs) are one of the most powerful features in Active Directory. They allow admins to enforce security settings, control user environments, and manage software configuration across an entire network – all from a single place, without touching each machine individually.

GPOs can also be used to grant or restrict privileges based on a user's role. For example, a regular employee might not need access to the Control Panel or the ability to change system settings, while an IT admin would.

In this lab, the following GPOs were configured and applied to the LAB.local domain environment.

- **Account Lockout Policy** – locks accounts after a set number of failed login attempts
- **Password Complexity Policy** – enforces minimum length and complexity requirements
- **Prohibit Access to Control Panel** – prevents users from changing system settings
- **Desktop Wallpaper Enforcement** – forces a specific wallpaper on all user machines

Key Concept – Computer vs User Configuration

Inside the Group Policy Management Editor, every GPO has two main sections:

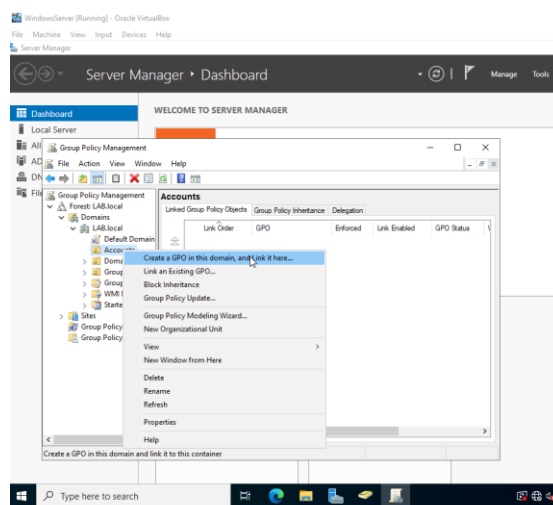
- **Computer Configuration** – policies that apply to the machine itself, regardless of who is logged in. These take effect when the computer starts up.
- **User Configuration** – policies that apply to the user, regardless of which machine they log into. They take effect when the user logs in.

Note: Account and password policies live under Computer Configuration because they are machine-level security settings. Control Panel and Wallpaper restrictions live under User Configuration because they follow the user around.

Create a GPO

Before adding any policies, a GPO needs to be created and linked to the right location in Active Directory. Where you link it determines who it applies to.

1. In Server Manager, go to **Tools > Group Policy Management**.
2. In the left panel, expand **Fores: LAB.local > Domains > LAB.local** to see the OUs and existing Group Policy links.
3. To apply a GPO to a specific OU, right-click that OU (e.g., **Accounts**) and select **Create a GPO in this domain, Link it here**.
4. Give the GPO a descriptive name (e.g., **Account Lockout Policy** or **User Restrictions**) and click OK.
5. The GPO will now appear linked under that OU. Right-click it and select **Edit** to open the Group Policy Management Editor and start configuring policies.



Important: Account Lockout and Password Policies must be linked at the domain level (directly on LAB.local), not on a specific OU. These are special policies that only work when applied domain-wide.

GPO 1 – Account Lockout Policy

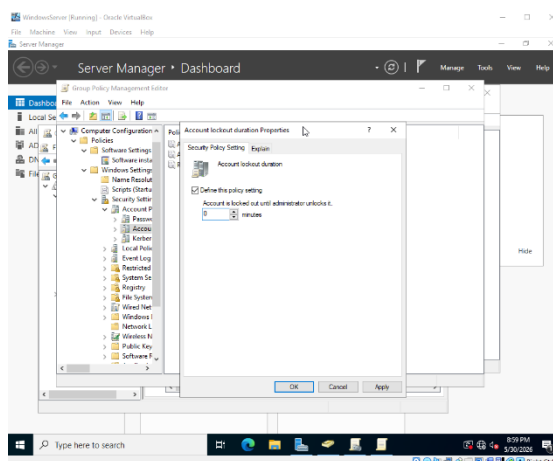
This policy automatically locks a user's account after a set number of failed login attempts. It's a key security measure that protects against brute force attacks – where someone repeatedly guesses passwords until they get in.

Configuration Path

Computer Configuration > Policies > Windows Settings > Security > Settings > Account Policies > Account Lockout Policy

Settings Applied

- **Account Lockout Threshold:** 3 invalid attempts – account locks after 3 wrong passwords
- **Account Lockout Duration:** 0 – accounts stay locked until an admin unlocks them
- **Reset Account Lockout Counter After:** 3 minutes – failed attempt count resets after 3 minutes of no attempts



Best Practice: Setting the duration to 0 (admin unlock required) is the strictest and most common setting in real enterprise environments. It prevents an attacker from just waiting out a timed logout.

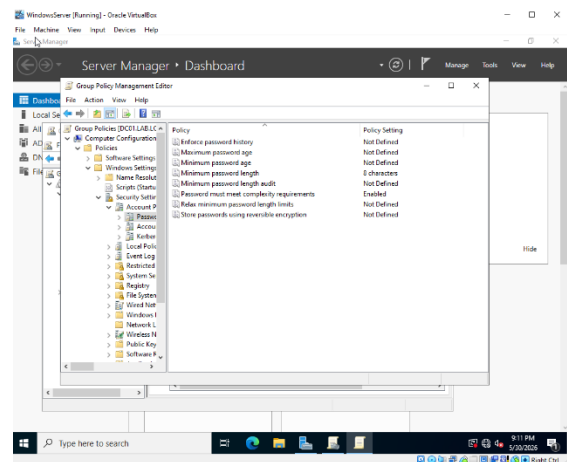
Note: Domain admin accounts are exempt from lockout policies by default. This is intentional – Microsoft does this to prevent admins from ever being completely locked out of the domain. To test this policy, use a regular domain user account like LAB\BCampbell.

GPO 2 – Password Complexity Policy

This policy enforces minimum standards for user passwords. Weak passwords are one of the most common entry points for attackers, so enforcing complexity requirements is a fundamental security practice.

Configuration Path

Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy



Settings Applied

- **Minimum Password Length:** 8 characters – passwords must be at least 8 characters long
- **Password Must Meet Complexity Requirements:** Enabled – passwords must include a mix of uppercase, lowercase, numbers, and special characters

Best Practice: In real enterprise environments, the minimum is usually 12 characters or more, and complexity requirements are always enabled. 8 characters is the bare minimum – longer is always better.

GPO 3 – Prohibit Access to Control Panel

This policy prevents regular users from opening the Control Panel or PC settings. It might seem strict, but there are good reasons for it in a managed environment.

Why This is Applied

- Prevent users from accidentally changing network settings, which could disconnect them from the domain or cause connectivity issues
- Stops users from uninstalling company-approved software or installing unauthorized programs.
- Reduces the chance of users changing security settings that IT has put in place

- Keeps the environment consistent and easier to manage and troubleshoot from the admin side

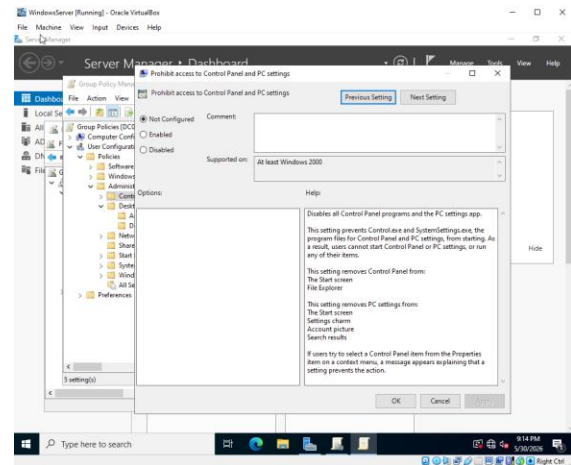
Configuration Path

User Configuration > Policies > Administrative Templates > Control Panel

Steps

6. In the Group Policy Management Editor, go to the path above.
7. Double-click **Prohibit access to Control Panel and PC Settings**.
8. Set it to **Enabled** and click Apply, then OK.

Note: This is a User Configuration policy, meaning it follows the user. Wherever a restricted user logs in, Control Panel will be blocked on that session.



GPO 4 – Desktop Wallpaper Enforcement

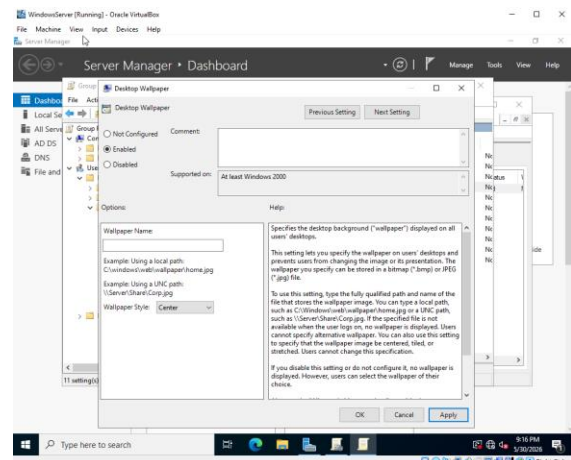
This policy forces a specific desktop wallpaper on all user machine and prevents users from changing it. While it sounds minor, there are practical reasons companies enforce this.

Why This is Applied

- Companies use wallpapers to display security notices or acceptable use policy reminders – something the user sees every time they unlock their screen
- Prevents users from setting inappropriate or distracting wallpapers in a professional environment
- Keeps the visual environment consistent across all machines, which makes it easier for IT to identify company devices
- In high-security environments, custom wallpapers can sometimes be used to display classification labels or data handling reminders

Configuration Path

User Configuration > Policies > Administrative Templates > Desktop > Desktop > Desktop Wallpaper



Steps

9. In the Group Policy Management Editor navigate to the path above.
10. Double-click **Desktop Wallpaper**.
11. Set it to **Enabled**.
12. In the Wallpaper **Name** field, enter the local path to the wallpaper file – for example:
C:\Windows\Web\Wallpaper\Windows\img0.jpg
13. Set **Wallpaper Style** to **Fill** for best results.
14. Click Apply then OK

Note: The wallpaper file path must exist on the local machine. If you want the same wallpaper on all machines, the file either needs to be on each machine or stored on a shared network path that all machines can access.

Applying the GPO

After creating and configuring a GPO, it doesn't apply instantly. Group Policy refreshes on a schedule, but you can force it manually for testing purposes

On the Windows 11 client machine, open Command Prompt and run:

gpupdate /force

To verify which GPOs are currently applied to the machine, run:

gpresult /r

Note: Some policies – especially Computer Configuration ones – require a full restart to take effect, not just gpupdate. If a policy doesn't seem to be applying after the force update, restart the client VM and test again.

Key Takeaways

- **GPOs are applied by location** – where you link the GPO determines who it affects. OU level, domain level, or site level all behave differently.
- **Account and password policies must be at the domain level** – linking them to a specific OU won't work for these two
- **Computer Configuration vs User Configuration** – knowing which one to use is important. Computer policies apply to the machine, user policies follow the person
- **gpupdate /force** – your best friend when testing GPOs. Always run this after making changes before assuming something isn't working

- **Domain admins are exempt from lockout** – always test lockout policies with a regular domain user account
- **GPOs are one of the most common interview topics** – being able to explain what they are, why they're used, and walk through a configuration is a big advantage in IT interviews